

Web Application Penetration Test – Vulniversity

Executive Summary

An authorized assessment of the TryHackMe Vulniversity lab was performed. The assessment identified an insecure file upload mechanism that could lead to remote code execution, followed by a privilege escalation path resulting in administrative access. The findings demonstrate the importance of secure input validation and least-privilege configuration.

Scope

Target: TryHackMe Vulniversity lab
Environment: Authorized training lab
Testing Type: Black-box

Methodology

Reconnaissance: Service discovery and version detection.
Enumeration: Web application and directory enumeration.
Exploitation: Validation of insecure file upload controls.
Privilege Escalation: Enumeration of Linux privilege escalation opportunities.

Findings

1. Insecure File Upload Validation (High): The application accepted an executable server-side file through insufficient extension validation, enabling code execution.
2. Privilege Escalation Misconfiguration (High): A privileged executable allowed elevation to administrative privileges after initial access.

Remediation

Implement allowlist-based file validation, store uploads outside the web root, disable execution in upload directories, apply least privilege, and regularly audit privileged binaries.

Skills Demonstrated

Nmap, Gobuster, Burp Suite, Linux enumeration, report writing, web application assessment.

Disclaimer

This assessment was conducted solely within the authorized TryHackMe training environment for educational purposes.